

Vertrag über die Verarbeitung personenbezogener Daten im Auftrag

(Auftragsverarbeitungsvertrag – AVV) gemäß Art. 28 DSGVO

Version: 1.0 (Entwurf) · Stand: 22.05.2026

⚠ **Auszufüllen / zu prüfen vor Unterzeichnung** (gelb markierte Felder [● ...]): Vollständige Firmierung, Anschrift, Registergericht/-nummer und vertretungsberechtigte Person des **Auftragsverarbeiters** (Betreiber von `app.autohausautomation.de`) sowie die **verbindlichen Stammdaten der Wackenhut Autohaus GmbH** (die hier eingesetzte Anschrift stammt aus Demo-Daten der Anwendung und ist zu verifizieren). Siehe auch den Hinweiskasten am Ende des Dokuments.

Zwischen

[● **Vollständige Firmierung des Auftragsverarbeiters, z. B. AutohausAutomation GmbH**] [● Straße, Hausnummer] [● PLZ, Ort] [● Registergericht, HRB-Nummer] vertreten durch [● Geschäftsführer/Inhaber]

– nachfolgend „**Auftragsverarbeiter**“ oder „**AV**“ –

und

Wackenhut Autohaus GmbH [● Königstraße 1, 70173 Stuttgart – aus Demo-Daten, bitte verifizieren] [● Registergericht, HRB-Nummer] vertreten durch [● Geschäftsführer]

– nachfolgend „**Verantwortlicher**“ oder „**Auftraggeber**“ –

– AV und Verantwortlicher einzeln auch „**Partei**“, gemeinsam „**Parteien**“ –

Präambel

Der Auftragsverarbeiter stellt dem Verantwortlichen die SaaS-Anwendung unter `app.autohausautomation.de` (nachfolgend „**Anwendung**“) zur Verfügung. Die Anwendung unterstützt den Verantwortlichen u. a. bei der Bearbeitung von Rückrufanfragen und Leads, der Terminierung und SLA-Steuerung, dem E-Mail-Versand von Benachrichtigungen, KI-gestützter Telefonie, der Verifizierung von Geschäftspartnern (KYC) sowie angrenzenden Funktionen (Fahrzeug-/Inserate-Verwaltung, Buchhaltung, Einkauf).

Bei der Erbringung dieser Leistungen verarbeitet der Auftragsverarbeiter personenbezogene Daten ausschließlich im Auftrag und nach Weisung des Verantwortlichen. Dieser Vertrag konkretisiert die datenschutzrechtlichen Rechte und Pflichten der Parteien im Zusammenhang mit dieser Verarbeitung und erfüllt die Anforderungen des Art. 28 Abs. 3 DSGVO.

Dieser AVV ist Bestandteil des zwischen den Parteien geschlossenen Hauptvertrags über die Nutzung der Anwendung (nachfolgend „**Hauptvertrag**“). Im Verhältnis zu datenschutzrechtlichen Fragen geht dieser AVV

dem Hauptvertrag vor.

§ 1 Gegenstand, Definitionen und Rangfolge

(1) Gegenstand dieses Vertrags ist die Verarbeitung personenbezogener Daten durch den Auftragsverarbeiter im Auftrag des Verantwortlichen im Rahmen der Erbringung der im Hauptvertrag vereinbarten Leistungen.

(2) Gegenstand, Art und Zweck der Verarbeitung, die Arten personenbezogener Daten, die Kategorien betroffener Personen sowie die Dauer der Verarbeitung ergeben sich aus **Anlage 1** (Beschreibung der Verarbeitung).

(3) Die in diesem Vertrag verwendeten Begriffe entsprechen den Definitionen der Datenschutz-Grundverordnung (Verordnung (EU) 2016/679 – „**DSGVO**“) und des Bundesdatenschutzgesetzes („**BDSG**“). Insbesondere gelten die Begriffsbestimmungen des Art. 4 DSGVO.

(4) Bei Widersprüchen zwischen den Vertragsdokumenten gilt folgende Rangfolge: (i) zwingende gesetzliche Regelungen, (ii) dieser AVV einschließlich seiner Anlagen, (iii) der Hauptvertrag. Innerhalb dieses AVV gehen die Regelungen des Hauptteils den Anlagen vor, soweit nicht ausdrücklich etwas anderes bestimmt ist.

§ 2 Anwendungsbereich und datenschutzrechtliche Verantwortlichkeit

(1) Der Verantwortliche ist im Rahmen dieses Vertrags **Verantwortlicher** im Sinne des Art. 4 Nr. 7 DSGVO. Er ist allein für die Rechtmäßigkeit der Verarbeitung sowie für die Wahrung der Rechte der betroffenen Personen verantwortlich.

(2) Der Auftragsverarbeiter ist **Auftragsverarbeiter** im Sinne des Art. 4 Nr. 8 DSGVO und verarbeitet die personenbezogenen Daten ausschließlich im Auftrag und nach dokumentierter Weisung des Verantwortlichen.

(3) Soweit der Auftragsverarbeiter personenbezogene Daten zu eigenen Zwecken und in eigener Verantwortung verarbeitet (z. B. Abrechnung, gesetzliche Aufbewahrungspflichten, Sicherstellung der IT-Sicherheit eigener Systeme), gilt dieser AVV insoweit nicht; der Auftragsverarbeiter ist hierfür eigenständig Verantwortlicher.

(4) Der räumliche Anwendungsbereich dieses Vertrags ist das Gebiet der Europäischen Union und des Europäischen Wirtschaftsraums (EWR). Verarbeitungen außerhalb dieses Gebiets sind nur unter den Voraussetzungen des § 7 zulässig.

§ 3 Weisungsrecht des Verantwortlichen

(1) Der Auftragsverarbeiter verarbeitet personenbezogene Daten ausschließlich im Rahmen der getroffenen Vereinbarungen und nach den dokumentierten Weisungen des Verantwortlichen, es sei denn, er ist nach dem Recht der Union oder der Mitgliedstaaten zur Verarbeitung verpflichtet (Art. 28 Abs. 3 lit. a DSGVO). In einem solchen Fall teilt der Auftragsverarbeiter dem Verantwortlichen diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.

(2) Weisungen werden zunächst durch diesen Vertrag und seine Anlagen festgelegt und können vom Verantwortlichen danach in Textform (Art. 28 Abs. 9 DSGVO; per E-Mail genügend) geändert, ergänzt oder ersetzt werden (Einzelweisungen). Mündliche Weisungen sind unverzüglich in Textform zu bestätigen.

(3) Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 Satz 3 DSGVO). Der Auftragsverarbeiter ist berechtigt, die Durchführung der betreffenden Weisung auszusetzen, bis sie vom Verantwortlichen bestätigt oder geändert wird.

(4) Die weisungsberechtigten und weisungsempfangenden Personen beider Parteien werden in **Anlage 4** benannt. Änderungen sind der jeweils anderen Partei in Textform mitzuteilen.

§ 4 Pflichten des Auftragsverarbeiters

Der Auftragsverarbeiter verpflichtet sich, insbesondere

- (1) personenbezogene Daten ausschließlich gemäß § 3 zu verarbeiten;
 - (2) die Vertraulichkeit gemäß § 11 zu gewährleisten und sicherzustellen, dass die zur Verarbeitung befugten Personen zur Vertraulichkeit verpflichtet sind oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b DSGVO);
 - (3) die technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO gemäß § 5 und **Anlage 2** zu ergreifen und einzuhalten;
 - (4) die Bedingungen für die Inanspruchnahme von Subunternehmern gemäß § 6 einzuhalten;
 - (5) den Verantwortlichen bei der Erfüllung der Betroffenenrechte gemäß § 8 zu unterstützen;
 - (6) den Verantwortlichen bei der Einhaltung der Pflichten aus Art. 32 bis 36 DSGVO gemäß § 9 zu unterstützen;
 - (7) nach Wahl des Verantwortlichen alle personenbezogenen Daten nach Abschluss der Verarbeitung gemäß § 13 zu löschen oder zurückzugeben;
 - (8) dem Verantwortlichen alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung zu stellen und Überprüfungen gemäß § 12 zu ermöglichen und dazu beizutragen;
 - (9) einen Datenschutzbeauftragten zu benennen, soweit er hierzu gesetzlich verpflichtet ist, und dem Verantwortlichen dessen Kontaktdaten auf Anfrage mitzuteilen. [**• Kontaktdaten DSB des AV, falls bestellt**];
 - (10) ein Verzeichnis aller Kategorien von im Auftrag des Verantwortlichen durchgeführten Verarbeitungstätigkeiten gemäß Art. 30 Abs. 2 DSGVO zu führen;
 - (11) den Verantwortlichen unverzüglich zu informieren, wenn eine Aufsichtsbehörde gegenüber dem Auftragsverarbeiter Maßnahmen im Zusammenhang mit der Auftragsverarbeitung ergreift.
-

§ 5 Technische und organisatorische Maßnahmen (TOM)

(1) Der Auftragsverarbeiter trifft die zur Gewährleistung eines dem Risiko angemessenen Schutzniveaus erforderlichen technischen und organisatorischen Maßnahmen gemäß Art. 32 DSGVO. Die zum Zeitpunkt des Vertragsschlusses getroffenen Maßnahmen sind in **Anlage 2** beschrieben.

(2) Die TOM unterliegen dem technischen Fortschritt und der Weiterentwicklung. Der Auftragsverarbeiter ist berechtigt, die TOM anzupassen, sofern das vereinbarte Schutzniveau dadurch nicht unterschritten wird. Wesentliche Änderungen sind zu dokumentieren und dem Verantwortlichen auf Anfrage nachzuweisen.

(3) Der Auftragsverarbeiter überprüft, bewertet und evaluiert die Wirksamkeit der TOM regelmäßig (Art. 32 Abs. 1 lit. d DSGVO).

§ 6 Inanspruchnahme weiterer Auftragsverarbeiter (Subunternehmer)

(1) Der Verantwortliche erteilt dem Auftragsverarbeiter die **allgemeine schriftliche Genehmigung** zur Inanspruchnahme weiterer Auftragsverarbeiter (Subunternehmer) im Sinne des Art. 28 Abs. 2 Satz 1 und Abs. 4 DSGVO. Die zum Zeitpunkt des Vertragsschlusses genehmigten Subunternehmer sind in **Anlage 3** aufgeführt.

(2) Der Auftragsverarbeiter informiert den Verantwortlichen über jede beabsichtigte Hinzuziehung oder Ersetzung von Subunternehmern in Textform mindestens **dreißig (30) Tage** vor der Beauftragung und gibt ihm damit die Möglichkeit, gegen derartige Änderungen Einspruch zu erheben (Art. 28 Abs. 2 Satz 2 DSGVO).

(3) Der Verantwortliche kann der Änderung innerhalb von **vierzehn (14) Tagen** nach Zugang der Information aus wichtigem datenschutzrechtlichem Grund in Textform widersprechen. Erhebt der Verantwortliche keinen Widerspruch innerhalb dieser Frist, gilt die Änderung als genehmigt. Im Fall eines berechtigten Widerspruchs sind die Parteien bemüht, eine einvernehmliche Lösung zu finden. Gelingt dies nicht und kann der Auftragsverarbeiter die Leistung ohne den betreffenden Subunternehmer nicht zu zumutbaren Bedingungen erbringen, ist jede Partei berechtigt, den betroffenen Leistungsteil mit angemessener Frist zu kündigen.

(4) Der Auftragsverarbeiter verpflichtet jeden Subunternehmer durch Vertrag auf datenschutzrechtliche Verpflichtungen, die denen dieses Vertrags im Wesentlichen entsprechen, insbesondere auf hinreichende Garantien zur Durchführung geeigneter technischer und organisatorischer Maßnahmen (Art. 28 Abs. 4 DSGVO). Kommt der Subunternehmer seinen Datenschutzpflichten nicht nach, haftet der Auftragsverarbeiter gegenüber dem Verantwortlichen für die Einhaltung der Pflichten des Subunternehmers.

(5) Als Subunternehmer im Sinne dieser Vorschrift gelten nicht Dienstleistungen, die der Auftragsverarbeiter als reine Nebenleistung in Anspruch nimmt (z. B. Telekommunikations-, Post-/Transport-, Wartungs- und Reinigungsdienste). Der Auftragsverarbeiter ist jedoch verpflichtet, auch bei solchen Nebenleistungen angemessene Vorkehrungen zur Wahrung des Datenschutzes zu treffen.

§ 7 Verarbeitung in Drittländern

(1) Eine Verarbeitung personenbezogener Daten in einem Drittland (außerhalb EU/EWR) findet nur statt, soweit die besonderen Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind, insbesondere bei Vorliegen eines Angemessenheitsbeschlusses (Art. 45 DSGVO) oder geeigneter Garantien (Art. 46 DSGVO, insbesondere EU-Standardvertragsklauseln nach Durchführungsbeschluss (EU) 2021/914), erforderlichenfalls ergänzt um zusätzliche Schutzmaßnahmen (Transfer Impact Assessment).

(2) Die eingesetzte Anwendung wird grundsätzlich innerhalb der EU/des EWR betrieben (Datenbank und Datei-Storage in Frankfurt/Deutschland, vgl. **Anlage 2** und **Anlage 3**). Im Rahmen des gewählten Betriebsmodells (Vercel + Supabase) sind jedoch folgende drittlandrelevanten Konstellationen ausdrücklich offenzulegen:

a) **Compute/Hosting (Vercel)**: Die Anwendungslogik wird über einen Anbieter mit US-amerikanischer Konzernmutter betrieben. Die Ausführung kann auf die Region Frankfurt festgelegt werden (Region-Pinning); es kann jedoch zu Zugriffen aus einem Drittland (insbesondere USA) im Rahmen von Betrieb, Support und Wartung kommen. Soweit der Anbieter unter dem EU-U.S. Data Privacy Framework zertifiziert ist, stützt sich der Transfer auf Art. 45 DSGVO; ergänzend werden EU-Standardvertragsklauseln vereinbart.

b) **KI-Bildgenerierung (fal.ai):** Soweit hierbei personenbezogene Daten verarbeitet werden, kann eine Verarbeitung in einem Drittland (USA) erfolgen. Der Auftragsverarbeiter stellt sicher, dass für diese Funktion keine personenbezogenen Daten betroffener Personen des Verantwortlichen ohne geeignete Garantien übermittelt werden.

c) **KI-Telefonie (NLPearl):** Die Datenresidenz dieses Subunternehmers ist abschließend zu verifizieren. Bis zum Nachweis einer EU-Verarbeitung oder geeigneter Garantien (Art. 46 DSGVO) erfolgt keine Übermittlung von Klardaten in ein Drittland; andernfalls werden EU-Standardvertragsklauseln nebst Transfer Impact Assessment abgeschlossen.

(3) Der Auftragsverarbeiter stellt dem Verantwortlichen auf Anfrage Nachweise über die getroffenen Garantien (Angemessenheitsbeschluss, Standardvertragsklauseln, Zertifizierungen, TIA) zur Verfügung.

(4) Der Verantwortliche bevollmächtigt den Auftragsverarbeiter, im Namen und für Rechnung des Verantwortlichen mit Subunternehmern EU-Standardvertragsklauseln (Modul 3: Auftragsverarbeiter-zu-Auftragsverarbeiter) abzuschließen, soweit dies zur Absicherung von Drittlandtransfers erforderlich ist.

§ 8 Wahrung der Betroffenenrechte

(1) Der Auftragsverarbeiter unterstützt den Verantwortlichen nach Möglichkeit mit geeigneten technischen und organisatorischen Maßnahmen dabei, seiner Pflicht zur Beantwortung von Anträgen betroffener Personen auf Wahrnehmung ihrer Rechte nach Kapitel III der DSGVO nachzukommen (Art. 28 Abs. 3 lit. e DSGVO), insbesondere bei Auskunft, Berichtigung, Löschung, Einschränkung der Verarbeitung, Datenübertragbarkeit und Widerspruch.

(2) Wendet sich eine betroffene Person unmittelbar an den Auftragsverarbeiter, leitet dieser das Anliegen unverzüglich an den Verantwortlichen weiter und beantwortet es nicht selbst, es sei denn, er ist hierzu vom Verantwortlichen angewiesen worden.

(3) Der Auftragsverarbeiter darf personenbezogene Daten nur auf Weisung des Verantwortlichen berichtigen, löschen oder deren Verarbeitung einschränken, es sei denn, dies ist nach den Anlagen oder durch die Funktionalität der Anwendung dem Verantwortlichen selbst möglich.

§ 9 Unterstützungsspflichten (Art. 32–36 DSGVO)

(1) Der Auftragsverarbeiter unterstützt den Verantwortlichen unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der in Art. 32 bis 36 DSGVO genannten Pflichten (Art. 28 Abs. 3 lit. f DSGVO), insbesondere bei

a) der Gewährleistung der Sicherheit der Verarbeitung (Art. 32), b) der Meldung von Verletzungen des Schutzes personenbezogener Daten an die Aufsichtsbehörde (Art. 33) und der Benachrichtigung betroffener Personen (Art. 34), c) der Durchführung von Datenschutz-Folgenabschätzungen (Art. 35) und d) der vorherigen Konsultation der Aufsichtsbehörde (Art. 36).

(2) Für Unterstützungsleistungen, die über die gesetzlichen Pflichten und den vertraglich geschuldeten Leistungsumfang hinausgehen und durch Umstände im Verantwortungsbereich des Verantwortlichen veranlasst sind, kann der Auftragsverarbeiter eine angemessene Vergütung nach Aufwand verlangen. [• **optional: Stundensatz / Konditionen**]

§ 10 Meldung von Verletzungen des Schutzes personenbezogener Daten

(1) Der Auftragsverarbeiter meldet dem Verantwortlichen jede ihm bekannt gewordene Verletzung des Schutzes personenbezogener Daten, die im Rahmen dieses Vertrags verarbeitet werden, **unverzüglich, spätestens jedoch innerhalb von 48 Stunden** nach Bekanntwerden (Art. 33 Abs. 2 DSGVO).

(2) Die Meldung erfolgt in Textform an die in **Anlage 4** benannte Stelle des Verantwortlichen und enthält, soweit verfügbar, mindestens:

a) eine Beschreibung der Art der Verletzung, soweit möglich mit Angabe der Kategorien und der ungefähren Zahl der betroffenen Personen sowie der betroffenen Datensätze; b) den Namen und die Kontaktdaten einer Auskunftsstelle; c) eine Beschreibung der wahrscheinlichen Folgen der Verletzung; d) eine Beschreibung der ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung der Verletzung und gegebenenfalls zur Abmilderung ihrer möglichen nachteiligen Auswirkungen.

(3) Sind nicht alle Informationen zugleich verfügbar, übermittelt der Auftragsverarbeiter sie ohne unangemessene weitere Verzögerung schrittweise nach.

(4) Der Auftragsverarbeiter ergreift unverzüglich die zur Eindämmung und Beseitigung der Verletzung erforderlichen Maßnahmen und dokumentiert sie. Die Meldung an die Aufsichtsbehörde und an betroffene Personen obliegt allein dem Verantwortlichen; der Auftragsverarbeiter ist hierzu ohne ausdrückliche Weisung nicht berechtigt.

§ 11 Vertraulichkeit

(1) Der Auftragsverarbeiter wahrt über alle ihm im Zusammenhang mit diesem Vertrag bekannt werdenden personenbezogenen Daten Verschwiegenheit. Diese Verpflichtung besteht auch nach Beendigung des Vertrags fort.

(2) Der Auftragsverarbeiter setzt zur Verarbeitung nur Personen ein, die zur Vertraulichkeit verpflichtet oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterworfen worden sind (Art. 28 Abs. 3 lit. b DSGVO). Die Verpflichtung erfolgt in einer den Nachweis ermöglichenden Form und gilt über das Beschäftigungsverhältnis hinaus fort.

(3) Der Auftragsverarbeiter stellt sicher, dass die zur Verarbeitung befugten Personen mit den einschlägigen Datenschutzbestimmungen vertraut sind und für ihre jeweiligen Aufgaben angemessen geschult werden.

§ 12 Nachweise und Kontrollen (Audit)

(1) Der Auftragsverarbeiter stellt dem Verantwortlichen alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO und in diesem Vertrag niedergelegten Pflichten zur Verfügung (Art. 28 Abs. 3 lit. h DSGVO).

(2) Der Nachweis der TOM kann erbracht werden durch a) die Vorlage geeigneter, aktueller Zertifizierungen, Testate oder Berichte (z. B. nach ISO 27001, SOC 2, BSI C5) – auch der eingesetzten Subunternehmer –, b) ausgefüllte und aktuelle Selbstauskünfte/Fragebögen oder c) eine angemessene Dokumentation der getroffenen TOM.

(3) Soweit die vorstehenden Nachweise nicht ausreichen, ermöglicht der Auftragsverarbeiter dem Verantwortlichen oder einem von diesem beauftragten, zur Verschwiegenheit verpflichteten und nicht mit dem

Auftragsverarbeiter im Wettbewerb stehenden Prüfer Überprüfungen, einschließlich Inspektionen, und trägt zu diesen bei (Art. 28 Abs. 3 lit. h DSGVO).

(4) Vor-Ort-Kontrollen sind mit angemessener Vorankündigung (in der Regel mindestens **vierzehn (14) Tage**), während der üblichen Geschäftszeiten, ohne Störung des Betriebsablaufs und grundsätzlich nicht häufiger als **einmal jährlich** durchzuführen, es sei denn, ein besonderer Anlass (z. B. eine Datenschutzverletzung oder eine Anordnung der Aufsichtsbehörde) rechtfertigt eine zusätzliche Kontrolle. Den durch eine Kontrolle entstehenden angemessenen Aufwand kann der Auftragsverarbeiter dem Verantwortlichen in Rechnung stellen, sofern die Kontrolle nicht durch ein Fehlverhalten des Auftragsverarbeiters veranlasst ist.

(5) Befindet sich Verarbeitungsumgebung bei einem Subunternehmer, gelten die Kontrollrechte entsprechend; der Auftragsverarbeiter wird die Ausübung durch geeignete vertragliche Regelungen mit dem Subunternehmer sicherstellen.

§ 13 Löschung und Rückgabe nach Beendigung

(1) Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht der Auftragsverarbeiter nach Wahl des Verantwortlichen alle personenbezogenen Daten oder gibt sie zurück und löscht vorhandene Kopien, sofern nicht nach dem Unionsrecht oder dem Recht der Mitgliedstaaten eine Verpflichtung zur Speicherung der personenbezogenen Daten besteht (Art. 28 Abs. 3 lit. g DSGVO).

(2) Der Verantwortliche teilt seine Wahl (Löschung oder Rückgabe) in Textform mit. Trifft er innerhalb von **dreißeig (30) Tagen** nach Beendigung keine Wahl, ist der Auftragsverarbeiter nach Ablauf einer Übergangsfrist berechtigt und verpflichtet, die Daten datenschutzgerecht zu löschen.

(3) Die Rückgabe erfolgt in einem gängigen, maschinenlesbaren Format. Eine etwaige Mitwirkung über den vertraglich geschuldeten Standardumfang hinaus (z. B. individuelle Exporte) kann der Auftragsverarbeiter angemessen vergüten lassen.

(4) Die Löschung ist dem Verantwortlichen auf Anfrage in Textform zu bestätigen. Backups werden im Rahmen der regulären Backup-Zyklen überschrieben; bis zur turnusmäßigen Überschreibung bleiben sie durch die TOM geschützt und werden nicht zu anderen Zwecken verarbeitet.

§ 14 Haftung

(1) Für die Haftung der Parteien gilt Art. 82 DSGVO. Im Innenverhältnis gelten ergänzend die Haftungsregelungen des Hauptvertrags, soweit sie zwingenden gesetzlichen Vorgaben nicht widersprechen.

(2) Der Verantwortliche ist für die Zulässigkeit der Verarbeitung sowie für die Wahrung der Rechte betroffener Personen allein verantwortlich (vgl. § 2 Abs. 1).

§ 15 Laufzeit und Kündigung

(1) Dieser Vertrag tritt mit Unterzeichnung durch beide Parteien in Kraft.

(2) Laufzeit und Beendigung dieses Vertrags richten sich nach dem Hauptvertrag. Dieser AVV endet automatisch mit Beendigung des Hauptvertrags, ohne dass es einer gesonderten Kündigung bedarf; die Pflichten aus § 11 (Vertraulichkeit) und § 13 (Löschung/Rückgabe) bestehen über das Vertragsende hinaus fort.

(3) Der Verantwortliche kann diesen Vertrag jederzeit aus wichtigem Grund kündigen, insbesondere bei einem schwerwiegenden Verstoß des Auftragsverarbeiters gegen datenschutzrechtliche Bestimmungen oder gegen diesen Vertrag, der nicht innerhalb einer angemessenen Frist abgestellt wird.

§ 16 Schlussbestimmungen

(1) Änderungen und Ergänzungen dieses Vertrags und seiner Anlagen bedürfen der Textform und des Hinweises darauf, dass es sich um eine Änderung bzw. Ergänzung dieses Vertrags handelt. Dies gilt auch für die Änderung dieses Textformerfordernisses.

(2) Sollten einzelne Bestimmungen dieses Vertrags unwirksam oder undurchführbar sein oder werden, so bleibt die Wirksamkeit des Vertrags im Übrigen unberührt. Die Parteien verpflichten sich, die unwirksame oder undurchführbare Bestimmung durch eine wirksame zu ersetzen, die dem wirtschaftlichen und datenschutzrechtlichen Zweck der ursprünglichen Bestimmung am nächsten kommt.

(3) Es gilt das Recht der Bundesrepublik Deutschland unter Ausschluss des UN-Kaufrechts. Gerichtsstand ist – soweit gesetzlich zulässig – der Sitz des Verantwortlichen.

(4) Dieser Vertrag besteht aus dem vorstehenden Hauptteil und den Anlagen 1 bis 4, die integraler Bestandteil dieses Vertrags sind.

Ort, Datum _____ **Ort, Datum** _____

Für den Auftragsverarbeiter Für den Verantwortlichen

[• Name, Funktion] [• Name, Funktion]

Anlage 1 – Beschreibung der Verarbeitung

1. Gegenstand und Art der Verarbeitung

Bereitstellung und Betrieb der SaaS-Anwendung `app.autohausautomation.de` zur Unterstützung der Geschäftsprozesse des Verantwortlichen. Verarbeitungsvorgänge umfassen: Erheben, Erfassen, Speichern, Organisieren, Ordnen, Anpassen, Abfragen, Verwenden, Übermitteln (E-Mail/Telefonie), Einschränken, Löschen und Vernichten personenbezogener Daten.

2. Zweck der Verarbeitung

Funktionsbereich	Zweck
Rückruf-/Leadmanagement	Erfassung und Bearbeitung von Rückrufanfragen und Leads, Zuweisung an Berater, SLA-/Fristensteuerung
Terminierung	Planung und Nachverfolgung von Rückrufen und Terminen
E-Mail-Benachrichtigung	Versand von Benachrichtigungen und Handlungs-Links an Mitarbeiter/Empfänger
KI-gestützte Telefonie	Automatisierte/unterstützte Anrufe inkl. Anrufprotokollierung
Verifizierung/KYC	Prüfung und Verifizierung von Geschäftspartnern (Handelsregister, USt-ID, Transparenzregister)
Angrenzende Module	Fahrzeug-/Inserate-Verwaltung, Einkauf, Buchhaltung

3. Art der personenbezogenen Daten

- **Stammdaten betroffener Personen:** Name, Telefonnummer, E-Mail-Adresse
- **Vorgangsdaten:** Rückrufgrund, Notizen, Status, Priorität, Quelle des Kontakts, Berater-/Bearbeiterzuordnung, SLA-/Fristdaten
- **Kommunikations-/Inhaltsdaten:** Anrufranskripte und Anrufdauer (KI-Telefonie), Datei-Anhänge zu Vorgängen (Inhalt durch den Verantwortlichen bestimmt)
- **Mitarbeiterdaten des Verantwortlichen:** Name, Mitarbeiter-ID, Rolle, Bearbeitungs-/Aktivitätsverläufe
- **Technische Daten:** IP-Adresse (z. B. bei Nutzung von Handlungs-Links), Zeitstempel, Protokolldaten (Logs)
- **Geschäftspartner-/KYC-Daten:** Firmenname, Ansprechpartner, Kontaktdaten, Handelsregister-/USt-ID-/Registerangaben

Besondere Kategorien (Art. 9 DSGVO): sind grundsätzlich **nicht** Gegenstand der Verarbeitung. Anrufranskripte und freie Notiz-/Anhangfelder können jedoch im Einzelfall unbeabsichtigt besondere Kategorien enthalten. Der Verantwortliche weist seine Nutzer an, solche Daten nicht in Freitextfeldern zu erfassen.

4. Kategorien betroffener Personen

- Kunden, Interessenten und Leads des Verantwortlichen (natürliche Personen)
- Mitarbeiter und Berater des Verantwortlichen (Nutzer der Anwendung)
- Ansprechpartner von Geschäftspartnern/Lieferanten (im Rahmen der Verifizierung)
- E-Mail-Empfänger von Benachrichtigungen

5. Dauer der Verarbeitung

Die Verarbeitung erfolgt für die Dauer des Hauptvertrags. Vorgangsbezogene Daten werden entsprechend den Weisungen und Aufbewahrungsfristen des Verantwortlichen gespeichert; danach gilt § 13. Token-/Aktionsdaten (z. B. E-Mail-Handlungs-Links) werden nach Ablauf ihrer Gültigkeit gelöscht. [• **Konkrete Aufbewahrungs-/Löschfristen je Datenkategorie durch den Verantwortlichen festzulegen.**]

Anlage 2 – Technische und organisatorische Maßnahmen

(Art. 32 DSGVO)

Wichtiger Umsetzungshinweis: Mehrere der nachstehenden Maßnahmen beschreiben den **vertraglich geschuldeten Zielzustand für den Produktivbetrieb mit echten Kunden- und Mitarbeiterdaten**. Nach dem internen Readiness-Befund (Stand 16.04.2026) sind insbesondere serverseitige Authentifizierung/Autorisierung, geschützte API-Endpunkte und ein produktionsstaugliches Datei-Storage **noch nicht vollständig umgesetzt**. Dieser AVV darf für die Verarbeitung echter Daten erst gezeichnet/aktiviert werden, wenn die als „erforderlich“ markierten Maßnahmen tatsächlich implementiert sind. Andernfalls würde der Auftragsverarbeiter Zusicherungen abgeben, die er nicht einhält.

1. Vertraulichkeit (Art. 32 Abs. 1 lit. b)

- **Zutrittskontrolle:** Verarbeitung in Rechenzentren der Subunternehmer mit zertifizierten physischen Zugangskontrollen (Supabase/AWS Frankfurt; Vercel). Kein eigenes Rechenzentrum des Auftragsverarbeiters.
- **Zugangskontrolle (erforderlich):** Serverseitige Authentifizierung aller Nutzer; individuelle Benutzerkonten; Passwortrichtlinien; Mehr-Faktor-Authentifizierung für administrative Zugänge.
- **Zugriffskontrolle (erforderlich):** Rollen- und berechtigungsbasierte Zugriffssteuerung serverseitig; Mandanten-/Tenant-Trennung; Row-Level-Security (RLS) in der Datenbank; Schutz aller personenbezogene Daten verarbeitenden API-Endpunkte gegen unauthentifizierten Zugriff; kein Service-Role-Schlüssel im Frontend.
- **Trennungskontrolle:** Logische Mandantentrennung der Daten des Verantwortlichen von Daten anderer Kunden.
- **Pseudonymisierung/Verschlüsselung:** Verschlüsselung der Daten bei der Übertragung (TLS) und im Ruhezustand (at rest) bei DB und Storage; Token werden nur als Hash gespeichert.

2. Integrität (Art. 32 Abs. 1 lit. b)

- **Weitergabekontrolle:** Verschlüsselte Übertragung (TLS) an alle Subunternehmer; E-Mail-Versand über europäische Relays (Brevo); Network/IP-Restriktionen für die Datenbank.
- **Eingabekontrolle:** Protokollierung von Aktivitäten und Bearbeitungsvorgängen (Activity-Log je Vorgang); Nachvollziehbarkeit von Erstellung/Änderung über Zeitstempel und Bearbeiterzuordnung.

3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b und c)

- **Verfügbarkeitskontrolle:** Verschlüsselte Backups (in transit und at rest) durch den DB-Subunternehmer; Wiederherstellbarkeit.
- **Rasche Wiederherstellbarkeit (Art. 32 Abs. 1 lit. c):** Backup-/Restore-Verfahren des DB-Anbieters; [• **RPO/RTO festlegen**].
- **Persistentes Storage (erforderlich):** Datei-Anhänge sind in einem persistenten, zugriffsgeschützten Objekt-Storage (nicht im lokalen, flüchtigen Dateisystem) abzulegen.

4. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d)

- Regelmäßige Überprüfung und Bewertung der Wirksamkeit der TOM.
- Patch-/Update-Management; Abhängigkeitsverwaltung.

- **Auftragskontrolle:** Verpflichtung der Subunternehmer per AVV/DPA; Prüfung der Zertifikate (ISO 27001, SOC 2, ggf. C5).
- **Datenschutzfreundliche Voreinstellungen (Art. 25):** Datenminimierung; Hinweis an Nutzer, keine besonderen Kategorien in Freitextfeldern zu erfassen.

5. Logging und Protokollierung

- Sicherheits- und Betriebs-Logs ohne unnötige personenbezogene Inhalte; angemessene Aufbewahrung und Zugriffsbeschränkung.

Anlage 3 – Genehmigte Subunternehmer

Stand: 22.05.2026. Allgemeine Genehmigung gemäß § 6 mit Informations- und Widerspruchsrecht.

#	Subunternehmer	Leistung	Verarbeitete Daten	Ort der Verarbeitung	Drittlandbezug / Garantie
1	Supabase (Supabase, Inc.)	PostgreSQL-Datenbank und Datei-Storage	sämtliche Vorgangs-, Stamm- und Inhaltsdaten	eu-central-1 , Frankfurt (DE)	US-Konzernmutter; DPA + EU-SCC; Hosting EU
2	Brevo (Sendinblue SAS)	Transaktions-/Benachrichtigungs-E-Mail	E-Mail-Adresse, Name, E-Mail-Inhalt	EU (Frankreich/europäische RZ)	EU; DPA
3	NLPearl	KI-gestützte Telefonie	Telefonnummer, Name, Anrufranskript, Anrufdauer	[• zu verifizieren]	Residenz offen; bis Nachweis EU keine Klardaten-Übermittlung, sonst EU-SCC + TIA
4	Vercel (Vercel, Inc.)	Compute/Hosting der Anwendung	sämtliche transient verarbeiteten Daten	Region Frankfurt (Pinning); Betrieb/Support ggf. USA	US-Konzern; DPF/EU-SCC; „no permanent EU storage"
5	fal.ai (Features Analytics Inc. o. ä.)	KI-Bildgenerierung	nur soweit personenbezogene Daten betroffen	USA	US; nur mit geeigneten Garantien bzw. ohne personenbezogene Daten betroffener Personen

Hinweis: Die genaue Firmierung/Anschrift der Subunternehmer ist vor Unterzeichnung anhand der jeweils aktuellen DPAs zu verifizieren und einzutragen.

Anlage 4 – Ansprechpartner und weisungsberechtigte Personen

Rolle	Auftragsverarbeiter	Verantwortlicher (Wackenhut)
Weisungsberechtigt	—	[• Name, Funktion, Kontakt]
Weisungsempfänger	[• Name, Funktion, Kontakt]	—
Datenschutzkoordination / DSB	[• falls bestellt]	[• DSB Wackenhut]
Meldungen nach § 10 (Vorfälle)	[• 24/7-Kontakt / E-Mail]	[• Sicherheits-/Datenschutzkontakt]

Offene Punkte vor Unterzeichnung (Checkliste)

1. **Parteien-Stammdaten** des Auftragsverarbeiters und verbindliche Wackenhut-Daten eintragen (Demo-Anschrift verifizieren).
2. **TOMs „erforderlich“** tatsächlich umsetzen (serverseitige Auth/Autorisierung, geschützte Endpunkte, persistentes Storage) — vgl. [SECURITY-DEPLOYMENT-READINESS.md](#).
3. **NLPearl-Datenresidenz** klären und AVV/SCC einholen; bis dahin keine Klardaten in Drittland.
4. **Aufbewahrungs-/Löschfristen** je Datenkategorie mit Wackenhut festlegen (Anlage 1 Ziff. 5).
5. **Subunternehmer-DPAs** (Supabase, Brevo, Vercel, fal.ai, NLPearl) einholen und Firmierungen verifizieren.
6. **RPO/RTO** und ggf. Vergütungssätze (§ 9 Abs. 2, § 13 Abs. 3) festlegen.